

CyBrain v4.1 — Guide des Vulnérabilités Détectées

34 Checks Apache + Nginx SSL | Sécurité CIS + Performance + TLS Avancé

Ce que server_int.py analyse réellement — scénarios d'attaque et corrections

Mars 2026 — Projet de Fin d'Études CyBrain

1. Périmètre et Nouveautés v4.1

Ce guide couvre uniquement les vulnérabilités détectées par `server_int.py` — pas de théorie OWASP générique. Chaque section correspond à une fonction `_check_*`() du code. v4.1 ajoute 3 nouveaux checks Apache (#32-#34) et complète la section Nginx SSL.

Checks	Catégorie	Contenu
#1-#24	Sécurité CIS	ServerTokens, SSL, Modules, Headers, Limits...
#25-#31	Performance Apache	MPM, MaxRequestWorkers, Cache, LogFormat...
#32 NOUVEAU	mod_rewrite Redirect Open	RewriteRule HTTP_HOST sans restriction domaine
#33 NOUVEAU	TLS Session Cache	SSLSessionCache, Timeout, SessionTickets
#34 NOUVEAU	MPM Params Coherence	MaxRequestWorkers = ServerLimit × ThreadsPerChild
Nginx SSL	ssl_stapling + tickets	OCSP stapling, PFS via session tickets off

2. Vulnérabilités Sécurité CIS — #1 à #24

2.1 Information Disclosure — #1, #2, #12

Directive vulnérable	Risque
ServerTokens Full (#1)	Server: Apache/2.4.51 (Ubuntu) OpenSSL/1.1.1l → attaquant cherche CVE exact
ServerSignature On (#2)	Version dans chaque page d'erreur 404/500 générée par Apache
expose_php=On (#12)	X-Powered-By: PHP/8.1.5 → attaquant cherche CVE PHP exact

```
# Corrections
ServerTokens Prod          # Envoie uniquement 'Apache'
ServerSignature Off
expose_php = Off           # php.ini
```

2.2 SSL/TLS — #5, #6, #7 (Critiques)

Vulnérabilité	Attaque
SSLv2/SSLv3 actifs	DROWN (2016), POODLE (2014) — déchiffrement rétrospectif de sessions anciennes
TLS 1.0/1.1 actifs	BEAST (2011), déprécié RFC 8996 — plus supporté par les navigateurs modernes
Ciphers RC4/DES/NULL	RC4 cassé statistiquement, DES brute-forceable, NULL = pas de chiffrement
SSLHonorCipherOrder Off	Serveur accepte le cipher faible proposé par le client — downgrade attack

```
# Correction CIS L1
SSLProtocol TLSv1.2 TLSv1.3
SSLCipherSuite ECDHE-ECDSA-AES256-GCM-SHA384:ECDHE-RSA-AES256-GCM-SHA384
SSLHonorCipherOrder On
```

2.3 Directory Traversal — #3, #4, #19

Directive	Scénario d'attaque
Options Indexes (#3)	GET /uploads/ → liste tous les fichiers sans index.html
FollowSymLinks (#4)	ln -s /etc/passwd /var/www/html/pass.txt → accès via HTTP
AllowOverride All (#19)	Upload .htaccess malveillant → RCE via CGI si uploads accessibles

```
# Corrections
Options -Indexes -FollowSymLinks
AllowOverride None
```

2.4 Modules Dangereux (#8)

```
# mod_status accessible sans auth
http://site.com/server-status → CPU, workers, toutes les requêtes en cours
# → Attaquant voit les sessions actives, URLs privées, paramètres en cours
```

```
# mod_userdir actif
http://site.com/~root/ → tente d'accéder au répertoire de root
# → Énumération des utilisateurs système

# Correction
a2dismod status info userdir cgi autoindex
```

2.5 LimitRequest* — #13 à #16

Directive manquante	Impact
LimitRequestLine absent	URL de 1 MB → buffer overflow dans modules CGI mal codés
LimitRequestFields absent	10 000 headers par requête → 10 000 allocations mémoire → DoS
LimitRequestBody absent	Upload de 10 GB → remplissage disque + saturation RAM → crash

```
LimitRequestLine      8190      # 8 KB max URI
LimitRequestFields    100       # 100 headers max
LimitRequestFieldSize 8190      # 8 KB par header
LimitRequestBody      10485760  # 10 MB max body
```

2.6 TraceEnable / HTTP Methods — #9, #18

```
# Cross-Site Tracing (XST) - TraceEnable On
TRACE / HTTP/1.1
Cookie: session=abc123
# Serveur retourne le cookie en echo → vol via XSS même avec HttpOnly

# PUT sans auth
PUT /shell.php HTTP/1.1 Content-Type: text/php
<?php system($_GET['cmd']); ?>
# → Upload de webshell direct sur le serveur

TraceEnable Off
<LimitExcept GET POST HEAD> Require all denied </LimitExcept>
```

3. Nouveaux Checks v4.1 — #32 à #34 + Nginx SSL

3.1 mod_rewrite Open Redirect (#32) — NOUVEAU

Scénario complet d'attaque Open Redirect via RewriteRule.

```
# Configuration vulnérable
RewriteEngine On
RewriteRule ^/(.*)$ https://%{HTTP_HOST}/$1 [R=301,L]

# Attaquant forge une requête :
GET / HTTP/1.1
Host: phishing-bank.evil.com

# Réponse du serveur :
HTTP/1.1 301 Moved Permanently
Location: https://phishing-bank.evil.com/

# Victime reçoit un lien http://banque.com → redirigé vers evil.com
# Browser affiche l'URL légitime au départ → confiance de la victime

# Correction — restreindre le domaine
RewriteCond %{HTTP_HOST} ^(www\.)?monsite\.com$ [NC]
RewriteRule ^/(.*)$ https://monsite.com/$1 [R=301,L]
```

CyBrain détecte le pattern RewriteRule ... https://(HTTP_HOST|{%HTTP_HOST}) et signale chaque occurrence avec numéro de ligne précis.

3.2 TLS Session Cache (#33) — NOUVEAU

Problème	Impact
SSLSessionCache absent	Chaque connexion HTTPS nécessite un handshake TLS complet — latence × 3-5
SSLSessionCacheTimeout absent	Sans timeout défini — comportement dépend de l'OS, difficile à auditer
SSLSessionTickets On (défaut)	Session tickets avec clés statiques = replay attack possible si clé compromise

```
# Configuration recommandée
SSLSessionCache          shmcb:/run/httpd/ssl_scache(512000) # 512KB partagé
SSLSessionCacheTimeout  300 # 5 minutes — équilibre perf/sécurité
SSLSessionTickets        Off # PFS strict — régénérer la clé à chaque redémarrage
```

3.3 MPM Params Coherence (#34) — NOUVEAU

Ce check détecte une incohérence silencieuse dans Apache qui peut conduire à un comportement de concurrence imprévisible.

```
# Exemple incohérent — Apache ignorera MaxRequestWorkers
ServerLimit          10 # Apache peut créer max 10 processus
ThreadsPerChild      50 # Chaque processus a 50 threads
MaxRequestWorkers    300 # ← Apache calculera 10×50=500 et ignorera 300
```

```
# Impact : le nombre réel de workers est 500, pas 300
# → Sous-dimensionnement apparent mais surcharge réelle en RAM

# Correction — MaxRequestWorkers doit = ServerLimit × ThreadsPerChild
ServerLimit      10
ThreadsPerChild  50
MaxRequestWorkers 500 = 10 × 50 ✓
```

3.4 Nginx SSL Avancé — ssl_stapling + ssl_session_tickets

Configuration	Risque
ssl_stapling off (défaut)	Client doit contacter le serveur OCSP séparément pour valider le certificat — +150ms latence
ssl_stapling_verify off	Serveur accepte des réponses OCSP non vérifiées — risque de stapling spoofing
ssl_session_tickets on (défaut)	Si la clé de tickets n'est pas rotée, une fuite de clé compromet les sessions passées

```
# Nginx — configuration SSL complète recommandée
ssl_protocols      TLSv1.2 TLSv1.3;
ssl_stapling       on;
ssl_stapling_verify on;
resolver           8.8.8.8 8.8.4.4 valid=300s; # Requis pour OCSP
ssl_session_tickets off; # Désactiver pour PFS strict
```

4. Ce que server_int.py Ne Vérifie Toujours PAS

Ces contrôles existent dans le CIS ou les bonnes pratiques mais ne sont pas implémentés en v4.1. Le jury peut poser des questions là-dessus.

Contrôle absent	Description
Authentification LDAP	AuthLDAPBindPassword en clair dans httpd.conf — credential leak
MPM env variables	SetEnvIf et configurations d'environnement par IP — cas avancé
HPKP	HTTP Public Key Pinning — déprécié mais encore dans certains benchmarks
ModPageSpeed	mod_pagespeed de Google — performance web avancée
Apache log rotation	LogRotate config externe — hors scope Apache config
Nginx rate limiting	limit_req_zone / limit_conn_zone — équivalent Nginx de rate limiting